DPDP Rules 2025 Handbook

Complete Compliance Guide for Digital Personal Data Protection Rules - Essential Guidelines for MSMEs in India

by Lex Praxis Compliance Team

Contents

01. Core Compliance Overview

Understanding DPDP Rules scope, definitions and key compliance deadlines for MSMEs.

02. Data Collection Guidelines

Customer notices, consent management and proper data collection procedures and practices.

03. Security Implementation

Practical low-cost security measures and data protection safeguards for businesses.

04. Breach Response

72-hour response plan, notification procedures and crisis management protocols.

DPDP Compliance Timeline for MSMEs

November 13, 2025 - Immediate

Rules 1-2 (Title & Definitions) and Rules 17-21 (Administrative rules for Data Protection Board setup) are immediately active and enforceable.

November 13, 2026 - Year One

Rule 4 (Registration of Consent Managers) becomes active. MSMEs are not required to hire Consent Managers as they are separate registered companies.

May 13, 2027 - Main Deadline

Key operational rules for MSMEs become effective. This is the main compliance deadline covering data collection, security, and processing requirements.

Future SDF Requirements

Significant Data Fiduciary obligations for large platforms with high user thresholds like 20 million registered users for e-commerce platforms.

Customer Notice Requirements Checklist

Before collecting any personal data, a Notice must be provided to customers in clear, plain language. This table outlines the mandatory requirements from Rule 3 with practical examples for local businesses to ensure proper compliance and customer transparency.

Requirement (Rule 3)	Why It Matters	Practical Example
Clear & Simple Language	Must be easily understandable	We collect data for loyalty program (NOT legal jargon)
Given Before Collection	Consent must be informed	Clear sign next to POS terminal
Itemised Data List	Customer right to know exactly	We collect: Full Name and Mobile Number
Specific Purpose Stated	Limits data usage scope	For: (1) Loyalty points (2) Promotional texts
Easy Consent Withdrawal	Fundamental customer right	Reply STOP or email privacy@shop.com
Access to Rights/Complaints	Clear channel required	Contact us at [Email/Phone] for updates

Customer Data Rights Under DPDP

Access

Information Access

Correct

Data Correction

Erase

Data Deletion

Withdraw

Consent Withdrawal

Access Rights

Customers have the right to access information about their data processing and request copies of their personal data.

- Provide clear information about data collection purposes
- Allow customers to request data copies easily
- Respond to access requests within reasonable timeframes

Correction & Erasure

Data subjects can request correction of inaccurate data and deletion when processing purpose is fulfilled.

- Implement system to update incorrect customer information
- Delete data when stated purpose is complete
- Maintain data only as long as legally necessary

Consent Management

Withdrawing consent must be as easy as giving consent. Businesses must stop processing upon withdrawal.

- Provide simple withdrawal mechanisms like STOP replies
- Immediately cease processing upon consent withdrawal
- Ensure withdrawal process is user-friendly and accessible

Low-Cost Security Measures Implementation

Reasonable security safeguards for MSMEs involve practical, low-cost steps based on Rule 6. These measures include password protection, limited access controls, data backups, and employee training to ensure comprehensive data protection without significant financial burden on small businesses.

Legal Requirement (Rule 6)	Practical Low-Cost Implementation
Encryption, Obfuscation, Masking	Use passwords on all devices; Auto-lock screens; Secure paper in locked drawers
Access Control	Limit employee access to necessary data only; Use strong unique passwords
Monitoring & Logs	Maintain employee access list; Enable system logs on POS/e-commerce platforms
Data Backups	Weekly backups to password-protected external drive or secure cloud service
Technical & Organisational Measures	Simple 1-page staff policy: Never share info, lock screens, report lost devices

72-Hour Data Breach Response Plan

A personal data breach includes unauthorized access, disclosure, alteration, use, or destruction of personal data. Upon becoming aware of a breach, MSMEs have urgent notification duties to affected customers and the Data Protection Board with specific timeframes and requirements.

Time Period	Required Actions
Hour 0-6 (Discovery)	Contain: Secure system, change passwords, wipe devices; Assess: Determine affected data; Notify: Call legal advisor
Hour 6-24	Draft customer notification in simple language; Submit initial Board report; Compile detailed report
Hour 24-72	Send clear notifications to all affected customers; Submit final comprehensive report to Board

Children's Data Protection

Age Verification Requirement

Collecting data from children under 18 requires verifiable consent from parent or guardian, creating high compliance burden for MSMEs.

Safest Path Strategy

For most MSMEs, the safest approach is to avoid collecting personal data from individuals under 18 entirely.



Compliance Risks

Children's data protection carries higher penalties and stricter enforcement, making avoidance the preferred business strategy.

Parental Consent Process

If collecting children's data, implement robust parental verification systems and maintain detailed consent records.

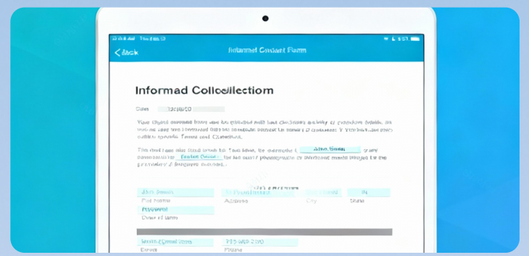
MSME vs Significant Data Fiduciary Obligations

MSMEs are generally not classified as Significant Data Fiduciaries (SDFs) and thus avoid expensive and complex obligations. The government targets large platforms with high user thresholds as SDFs, allowing smaller businesses to focus on basic compliance requirements.

Obligation (Rule 13)	SDF Requirement	MSME Requirement
Data Protection Impact Assessment	Formal periodic DPIA and annual data audit (costly external review)	Nothing required
Data Protection Officer	Must appoint senior-level DPO expert (high-salary position)	Only provide contact info for person able to answer questions
Algorithmic Verification	Must verify algorithmic software poses no risk to user rights	Nothing required
User Threshold	20 million registered users for e-commerce platforms	No threshold - basic compliance only

Understanding DPDP Rules 2025 Framework







Rules Scope Coverage

- Applies to any business processing digital personal data
- Covers organizations and individuals regardless of size
- Includes all data that can identify individuals

Data Fiduciary Responsibilities

- Businesses collecting customer data are Data Fiduciaries
- Responsible for protecting all collected personal information
- Must implement reasonable security safeguards and procedures

Processing Activities Covered

- Collection, storage, use, sharing, or deletion
- Any action performed on personal data
- Must maintain logs for security and legal purposes

Data Retention and Deletion Requirements

Retention Period Guidelines

Personal data can only be kept as long as the stated purpose is served. Once the purpose is complete, data must be erased unless other laws require retention. A mandatory one-year log retention period applies to processing logs.

Purpose-Based Retention

- Keep data only while serving stated collection purpose
- Erase immediately when purpose is fulfilled
- Follow other legal retention requirements if applicable

Log Retention Requirements

- Maintain processing logs for one year minimum
- Required for security and legal compliance
- Erase personal data from logs after retention period

Deletion Process

Implement systematic data deletion when retention expires.

Legal Requirements

Balance DPDP deletion with other legal retention needs.

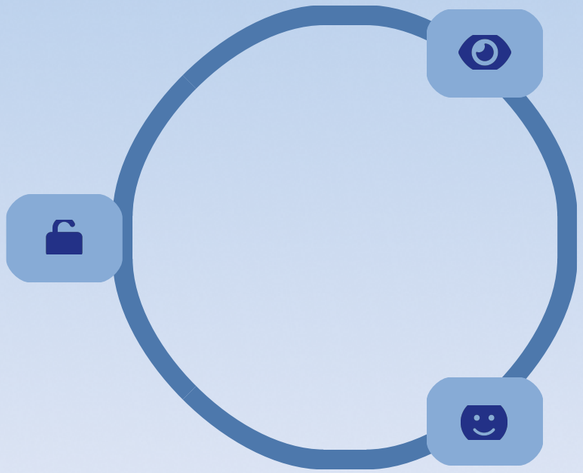
Backup Management

Ensure backups also follow retention and deletion rules.

Data Breach Definition and Response

Unauthorized Access

Any access to personal data by individuals or systems without proper authorization or permission, including both internal and external unauthorized access attempts that compromise data security.



Unauthorized Disclosure

Revealing personal data to parties who should not have access, whether intentional or accidental, including sharing data beyond authorized purposes or with unauthorized third parties.

Data Alteration

Unauthorized modification, corruption, or tampering with personal data that affects its accuracy, integrity, or reliability, whether through malicious actions or system failures that compromise data quality.

Employee Training and Organizational Measures

Staff Training Requirements

Implement comprehensive employee training programs to ensure all staff understand DPDP compliance requirements, data handling procedures, and security protocols for protecting customer personal information.

- Create simple one-page policy document for all employees to understand
- Train staff on never sharing customer information with unauthorized parties
- Ensure employees always lock screens when away from workstations

Security Protocol Implementation

Establish clear organizational measures and technical safeguards that create a culture of data protection and security awareness throughout the business operations.

- Implement immediate reporting procedures for lost or compromised devices
- Establish strong password policies and regular password update requirements
- Create access control systems limiting data access to necessary personnel only

MSME Compliance Implementation Steps

Step 1: Assess Current Data Processing

Conduct comprehensive audit of all personal data currently being collected, stored, and processed. Identify data sources, purposes, and current security measures in place.

Step 2: Create Customer Notices

Develop clear, plain-language notices for all data collection points. Ensure notices include itemized data lists, specific purposes, and easy withdrawal methods.

Step 3: Implement Security Measures

Deploy practical security safeguards including password protection, access controls, data backups, and employee training programs based on Rule 6 requirements.

Step 4: Establish Breach Response Plan

Create 72-hour response procedures including immediate containment, customer notification processes, and Data Protection Board reporting mechanisms for quick breach response.

Practical DPDP Compliance for Small Businesses





Retail Business Implementation

- Place clear data collection notices at POS terminals and signup locations
- Train cashiers on proper consent collection and customer rights explanation
- Implement simple customer database with access controls and backup procedures

Online Business Compliance

- Update website privacy policies with clear itemized data collection notices
- Implement easy consent withdrawal mechanisms like unsubscribe links
- Ensure secure data storage with encryption and regular security updates

"

Personal data can only be kept as long as the stated purpose is served; once complete, it must be erased.

— DPDP Rules 2025, Data Retention Principle

This fundamental principle ensures that businesses maintain data only when necessary for their stated purposes, protecting customer privacy and reducing compliance burden through systematic data lifecycle management and automatic deletion protocols.

Data Protection Board Interaction and Reporting

Data Protection Board Overview

The Data Protection Board serves as the regulatory authority for DPDP compliance enforcement. MSMEs must understand reporting requirements, breach notifications, and interaction protocols with this government body for proper compliance.

Breach Notification Timeline

- Initial notification without delay upon breach discovery
- Detailed comprehensive report within 72 hours
- Include causes, affected data, and mitigation measures

Required Documentation

- Maintain processing logs for one year minimum
- Document all security measures and employee training
- Keep records of customer consent and withdrawal requests

Contact Requirements

Provide clear contact information for data protection queries.

Compliance Audits

Be prepared for potential regulatory audits and inspections.

Penalty Awareness

Understand enforcement actions and penalty structures.

Best Practices for Ongoing DPDP Compliance



Regular Compliance Reviews

Conduct monthly reviews of data collection practices and security measures implementation.

Update customer notices and consent mechanisms as business processes evolve and change.



Continuous Staff Education

Provide ongoing training updates as DPDP rules evolve and new guidance emerges.

Ensure all new employees receive comprehensive data protection orientation and training programs.

Thank You

DPDP Rules 2025 compliance is achievable for MSMEs through practical implementation and systematic approach.